

DOCUMENT CONTROL

=====

Document ID : POL-2021-002
Document Title : Partner API Gateway Security Policy
Document Type : Policy
Version : 1.8
Status : Active
Effective Date : 15-Feb-2021
Review Date : 15-Feb-2022
Owner : API Gateway Team
Author : Sanjay Bose
Approved By : Rajesh Venkatraman, Service Delivery Manager (NexaTel)
Classification : Internal – NexaTel Managed Services
Last Revised : 15-May-2023

REVISION HISTORY

=====

Version	Date	Author	Summary of Changes
1.0	15-Feb-2021	Sanjay Bose	Initial Release
1.5	10-Oct-2022	Sanjay Bose	Updated rate limiting guidelines
1.8	15-May-2023	Sanjay Bose	Strengthened Section 4.2 per PRB-2023-0004 – per-tenant isolation now mandatory, not recommended

1. PURPOSE

=====

This policy defines the security and resource allocation standards for the Partner API Gateway (SVC-APIGW-001) to protect the API infrastructure from resource exhaustion and unauthorized access.

2. SCOPE

=====

This policy applies to all external partners and internal service consumers accessing the Partner API Gateway (SVC-APIGW-001) in the NexaTel production environment.

3. POLICY STATEMENT

=====

3.1 Tenant Isolation

Each partner tenant MUST have an isolated rate limit quota. Internal service-to-service calls (SVC-PROV-001, SVC-KYC-001, and other internal consumers) MUST be excluded from the external partner rate limit pool. Shared pool architecture is prohibited.

3.2 Authentication & Authorization

All gateway endpoints must use mutual TLS (mTLS) and OAuth2 token validation. JWT tokens must be validated at the gateway.

4. PROCEDURES

=====

4.1 Client Onboarding

4.1.1 Partners must register their IP ranges and upload public TLS certificates.

4.1.2 Gateway API keys must be generated and stored securely in the keystore.

4.2 Rate Limit Pool Allocation

Rate limit pool allocation: Each partner tenant maximum 20% of total pool. Internal service calls allocated from a dedicated internal pool (minimum 30% of total capacity, non-shareable). Total pool sizing must account for 200% burst headroom above P99 observed traffic.

5. ROLES AND RESPONSIBILITIES

=====

- API Platform SRE Lead (Sanjay Bose): Configure and monitor gateway policies.
- Partner SRE Lead (Nalini Iyer): Coordinate partner configurations.
- Audit Bot (ops.audit@asterion.example): Monitor rate limiting breaches.

6. EXCEPTIONS

=====

Any rate limit exception requires approval from Sanjay Bose and service.manager@nexatel.example.

7. COMPLIANCE AND ENFORCEMENT

=====

Exceeding rate limits will trigger automated ERR_GW_429 responses. Repeat violators will be blocked at the firewall.

8. RELATED DOCUMENTS

=====

- POL-2021-025 (Rate Limiting Policy)
- POL-2021-028 (Secure API Key Management Policy)